

Incident Response Policy

Version v1 · Effective 1 September 2025 · Status: published

Owner: Chief Information Security Officer · Category: Information security

Applies to: Technology

Fictional policy written for a software demonstration. Kestrel Mutual is an invented organization. This is not real policy, law or regulatory guidance.

1 Purpose

This policy sets how Kestrel Mutual reports, handles and learns from security incidents.

2 Definitions

2.1 Security incident

A “security incident” is any event that compromises, or could compromise, the confidentiality, integrity or availability of Kestrel Mutual information.

2.2 Personal data breach

A “personal data breach” is a security incident that leads to the accidental or unlawful loss, alteration or disclosure of, or access to, customer personal data.

3 Reporting

3.1 Staff reporting

Any member of staff who suspects a security incident must report it to the Security Operations Centre within one hour of noticing it.

3.2 No investigation before reporting

Staff must not investigate a suspected incident themselves before reporting it.

4 Handling

4.1 Severity

The Security Operations Centre assigns each incident a severity from 1 (critical) to 4 (low) within four hours of the report.

4.2 Data Protection Officer notification

If a personal data breach is likely to result in a risk to customers, the Data Protection Officer must be told within 24 hours of the breach being confirmed.

4.3 Customer communication

Customers are contacted about an incident only through messages approved by the Head of Communications.

5 Review

5.1 Post-incident review

A post-incident review is completed within 20 working days of closing any severity 1 or severity 2 incident.